TORTUGA CYBERSECURITY

EN

Phishing & Everyday Threat Awareness

A practical field guide for staying safe online

Phishing Fundamentals & Homograph Attacks

Phishing is the practice of impersonating a trusted party to trick you into surrendering credentials, payment details, or access. Most attacks arrive as email or messages that copy the look of a legitimate service and push you toward a fake login page. One of the hardest variants to spot is the homograph attack, where an attacker registers a domain that is visually almost identical to the real one. A lowercase letter l can be replaced with the digit 1, the letter o with a zero, or a Latin character with a lookalike from another alphabet. Your eyes read examp1e.com as example.com, but your browser treats them as two entirely different servers. The defense is procedural, not visual: never trust a link because it looks right. Reach sensitive sites through your own bookmarks or by typing the address, and inspect the full domain before entering any credential.

Key takeaways

- ✓ Phishing imitates trusted brands to steal credentials or payments.
- ✓ Homograph attacks swap characters (1 for l, 0 for o, lookalike alphabets) to forge domains.
- ✓ Visually checking a link is unreliable; the substitution is designed to pass a quick glance.
- ✓ Navigate to sensitive sites via bookmarks or typed addresses, never via message links.

→ **DO THIS TODAY**

Bookmark your bank, email, and workplace login pages right now, and use only those bookmarks from this point forward.

Two-Factor Authentication & Password Managers

Passwords fail in predictable ways. When one service is breached, the leaked credentials are replayed against every other popular site, an attack known as credential stuffing. It works because of a single root cause: password reuse. If your email password also unlocks your banking or work accounts, one unrelated breach cascades into all of them. Two controls break this chain. A password manager generates and stores a long, unique password for every account, so a leak at one site is contained to that site. Two-factor authentication (2FA) then defeats credential replay itself: even a correct stolen password is useless without the second factor you hold, whether that is an authenticator app code or a hardware key. App-based or hardware factors are stronger than SMS codes, which can be intercepted through SIM-swap fraud. Together these two habits neutralize the most common account-takeover path seen in practice.

Key takeaways

- ✓ Password reuse is the root cause that turns one breach into many.
- ✓ Credential stuffing replays leaked passwords across other services automatically.
- ✓ A password manager makes every password long, unique, and disposable.
- ✓ 2FA defeats credential replay: a stolen password alone no longer grants access.
- ✓ Prefer authenticator apps or hardware keys over SMS codes.

→ **DO THIS TODAY**

Enable 2FA on your primary email account today; it is the account that resets all the others.

Public Wi-Fi, Rogue Access Points & VPNs

Public Wi-Fi carries a specific risk model. Anyone can broadcast a network named after the café or airport you are sitting in, and your device cannot distinguish the legitimate access point from the rogue one. Once you connect to an attacker-controlled network, they sit in the middle of your traffic (a machine-in-the-middle position) and can observe unencrypted connections, tamper with responses, or redirect you to spoofed pages. A VPN changes exactly one thing: it encrypts the transport between your device and the VPN provider, so the rogue network operator sees only ciphertext. That is a real and useful guarantee. It is also a limited one. A VPN does not clean an already compromised endpoint, does not stop you from typing a password into a phishing page, and shifts trust to the VPN provider itself. Treat it as armor for the connection, not for the device or the person using it.

Key takeaways

- ✓ A rogue access point can perfectly imitate a legitimate network name.
- ✓ The attacker's position enables interception and manipulation of your traffic.
- ✓ A VPN encrypts transport, blinding the local network operator.
- ✓ A VPN does not fix a compromised device or prevent phishing.
- ✓ Choose a VPN provider you can actually justify trusting.

→ **DO THIS TODAY**

Turn off auto-join for open Wi-Fi networks on your phone and laptop so you connect deliberately, not automatically.

Ransomware & the 3-2-1 Backup Rule

HIGH IMPACT

Ransomware encrypts your files and demands payment for the key. Modern variants go further: they quietly seek out every drive and network share the infected machine can reach, including connected backup drives and synced cloud folders, and encrypt those too. A backup that is always attached to the computer it protects can die in the same incident. The 3-2-1 rule is the discipline that survives this: keep three copies of your data, on two different types of media, with one copy offsite or offline. The offline copy is the part that specifically defeats ransomware. Malware cannot encrypt a disk that is unplugged or a copy that is physically and logically disconnected at the moment of infection. Versioned cloud backups with retention also help, because you can roll back to a snapshot taken before the encryption began. Recovery capability, not the ransom, is your real leverage.

Key takeaways

- ✓ Ransomware encrypts everything the infected machine can reach, including attached backups.
- ✓ 3-2-1: three copies, two media types, one offsite or offline.
- ✓ An offline copy cannot be encrypted by malware running on the host.
- ✓ Versioned backups let you restore to a point before infection.
- ✓ Test restores; an unverified backup is a hypothesis, not a safeguard.

→ **DO THIS TODAY**

Copy your critical files to an external drive today, then unplug it and store it somewhere separate from your computer.

Vishing & Tech-Support Scams

Vishing is phishing by voice. A caller claims to be your bank, a government office, or a well-known software company, and reports an urgent problem: fraud on your account, a virus on your computer, a package held at customs. The technical details vary, but the persuasion levers do not. Urgency compresses your thinking time. Authority discourages you from questioning the caller. Fear makes a bad outcome feel imminent unless you act immediately. The goal is to get you to hand over codes, install remote-access software, or move money while you are still off balance. The single most effective counter is breaking the channel the attacker controls: hang up, find the organization's official number yourself, and call back. A legitimate institution will never object to that. No real bank or support desk asks you to read out a one-time code or grant remote control of your device on an unsolicited call.

Key takeaways

- ✓ Vishing applies urgency, authority, and fear to rush your decisions.
- ✓ Unsolicited calls requesting codes, remote access, or transfers are hostile by default.
- ✓ Hanging up and calling the official number breaks the attacker's channel.
- ✓ One-time codes are for you to enter, never to read aloud to a caller.

→ **DO THIS TODAY**

Save the official phone numbers of your bank and card issuer in your contacts now, so the safe callback path already exists when a suspicious call arrives.